

A Comparative Analysis of AI-Generated Security Policies for Mitigating Phishing Risks

**Written to fulfill the 2nd task of
Cyber Security Review**



UNIVERSITAS
INDONESIA

CEP-CCIT
FAKULTAS TEKNIK

Group 1:

Aldi Syarif Alhakim 2521010106

Alezuna M. Nadhif Pohan 2521010108

Muhamad Ihsan Rasyad 2521010138

Class: 2CS1

CEP CCIT

FACULTY OF ENGINEERING

UNIVERSITY OF INDONESIA

2026

PREFACE

We would like to express our sincere gratitude to God Almighty for His blessings and guidance that have allowed us to complete this academic work titled "A Comparative Analysis of AI-Generated Security Policies for Mitigating Phishing Risks." This project represents our collaborative effort as a group to evaluate the effectiveness of artificial intelligence in crafting robust security frameworks against the ever-evolving threat of phishing attacks.

Throughout the process of completing this paper, we have gained valuable insights into the comparison between traditional policy-making and AI-driven security governance. This study focuses on how AI can be utilized to generate adaptive policies that protect system integrity and user data from sophisticated social engineering threats that are becoming increasingly prevalent in today's digital landscape.

This work is inspired by the critical shift in the cybersecurity landscape, where static policies are no longer sufficient to defend against dynamic, AI-powered attacks. We hope that this analysis serves as a useful reference for students, developers, and security professionals who are interested in the intersection of artificial intelligence and cybersecurity management.

We would also like to express our appreciation to our instructors, classmates, and the technical community who have supported and guided us throughout the preparation of this work. We realize that this project is far from perfect and we welcome any constructive feedback and logical critiques that may help us improve this research in the future.

TABLE OF CONTENTS

PREFACE.....	i
TABLE OF CONTENTS.....	ii
TABLE OF FIGURE.....	iii
CHAPTER I.....	1
INTRODUCTION.....	1
1.1 Background.....	1
1.2 Writing Objective.....	1
1.3 Problem Domain.....	2
1.4 Writing Methodology.....	2
1.5 Writing Framework.....	2
CHAPTER II.....	3
BASIC THEORY.....	3
2.1 Phishing as a Cybersecurity Threat.....	3
2.2 Artificial Intelligence for Phishing Detection.....	3
2.3 Cybersecurity Policies and Procedures.....	3
2.4 Cybersecurity Policy Frameworks (NIST and ISO/IEC 27001).....	4
2.5 Analytic Hierarchy Process (AHP) in Risk Assessment.....	5
2.6 Multi-Factor Authentication (MFA) in Cybersecurity.....	6
2.7 Technical Controls and Email Security.....	7
CHAPTER III.....	8
COMPARATIVE ANALYSIS AND DISCUSSION.....	8
3.1 AI-Based Cybersecurity Policies and Procedures.....	8
3.2 AI Techniques for Cyber Security Risk Detection.....	8
3.3 AI in Phishing Detection (Case Study: ChatGPT).....	9
3.4 Mitigation Strategies for Phishing Attacks.....	9
A. AI-Based Phishing Detection Systems.....	10
B. Security Awareness and User Training.....	10
C. Implementation of Multi-Factor Authentication (MFA).....	10
D. AI-Generated and Adaptive Security Policies.....	11
E. Technical Controls and Email Security Measures.....	11
F. Continuous Monitoring and Incident Response.....	11
CHAPTER IV.....	12
CONCLUSION AND SUGGESTION.....	12
4.1 Conclusion.....	12
4.2 Suggestion.....	12
BIBLIOGRAPHY.....	13

TABLE OF FIGURE

Figure 2.1 NIST vs ISO	4
Figure 2.2 MFA	6
Figure 2.3 Email Security	7
Figure 3.1 NIST & ISO	8
Figure 3.2 AHP	8
Figure 3.3 Phishing Attack Prevention	9

CHAPTER I

INTRODUCTION

1.1 Background

In the current cybersecurity landscape, the human element remains the most persistent and exploited vulnerability. Despite the deployment of sophisticated technical safeguards, phishing has evolved from crude email scams into highly targeted social engineering attacks, such as "spear-phishing" and "quishing" (QR code phishing). Organizations rely on security policies to govern employee behavior and establish a baseline for defense, yet these documents are often static, cumbersome to produce, and fail to keep pace with the rapid innovation of threat actors.

The emergence of Large Language Models (LLMs) and Generative AI has introduced a tempting solution for this bottleneck. Organizations are increasingly utilizing AI to automate the creation of security protocols, aiming to achieve speed and professional formatting that would traditionally take weeks of manual labor. This shift promises a more dynamic approach to policy-making, where defensive documentation can theoretically be updated as fast as new threats emerge. However, this transition is occurring without a standardized framework for verifying the quality or accuracy of the AI's output.

This reliance creates a dangerous "trust gap." While AI can generate policies that sound authoritative and follow professional conventions, it often lacks the contextual nuance required to address sophisticated psychological manipulation. If an AI-generated policy is generic or contains technical "hallucinations," it provides a false sense of security while leaving critical gaps in an organization's armor. A comparative analysis is therefore essential to determine whether these AI tools are truly capable of producing robust, risk-compliant policies, or if they are merely creating an illusion of safety.

1.2 Writing Objective

This study aims to critically evaluate and compare the effectiveness of security policies generated by different AI models in the context of phishing mitigation.

1.3 Problem Domain

The core issue is the **Illusion of Security**. AI-generated policies often prioritize professional formatting over technical substance. This creates a dangerous gap where policies might satisfy auditors but fail to address modern, high-stakes threats like deepfake-based social engineering or quishing.

1.4 Writing Methodology

The writing method for this paper uses literature studies and qualitative analysis. The authors gather facts and technical data from academic journals and cybersecurity repositories regarding phishing patterns. The study focuses on evaluating the performance of large language models (llms), specifically using ChatGPT as a primary case study, to analyze its effectiveness in generating security policies and detecting phishing threats.

1.5 Writing Framework

CHAPTER I: INTRODUCTION

Describes the background, objectives, problem domain, methodology, and the general framework of the study.

CHAPTER II: BASIC THEORY

Explains the definitions of phishing, the architecture of Large Language Models, and the fundamental principles of security policy design.

CHAPTER III: COMPARATIVE ANALYSIS AND DISCUSSION

Discusses the application of ai in cybersecurity policy development and evaluates the effectiveness of ai models in detecting social engineering threats

CHAPTER IV: CONCLUSIONS AND SUGGESTIONS

Contains conclusions drawn from the discussion on ai-driven policies and provides suggestions for improving organizational cybersecurity frameworks.

CHAPTER II

BASIC THEORY

2.1 Phishing as a Cybersecurity Threat

Phishing remains one of the most pervasive and financially damaging threats in the modern digital landscape. It operates through two primary vectors: social engineering, which exploits human psychology to deceive victims, and technical subterfuge, which employs malware to steal credentials or redirect users to counterfeit websites. According to the APWG report, the fourth quarter of 2023 recorded a 7.8% increase in phishing incidents, totaling nearly 5 million reported cases. Specifically, Business Email Compromise (BEC) attacks accounted for \$51 billion in losses during the same period, underscoring the urgent need for advanced, scalable countermeasures beyond conventional rule-based filtering. *(De Rosa, Gringoli & Bellicini, 2024)*

2.2 Artificial Intelligence for Phishing Detection

Traditional detection mechanisms, such as static blacklists and firewalls, increasingly struggle to keep pace with evolving phishing techniques. Artificial Intelligence, particularly Machine Learning (ML) and Natural Language Processing (NLP), offers an adaptive alternative. Platforms like ChatGPT demonstrate high proficiency in contextualizing language to detect nuanced phishing patterns. Recent studies (e.g., De Rosa et al.) showed that ChatGPT-based frameworks can achieve an overall accuracy of 75.75% with a high sensitivity of 98.4%. However, the tendency for over-classification (53.1% specificity) remains a challenge, as it may flag legitimate communications as malicious. *(Parandhaman, 2025).*

2.3 Cybersecurity Policies and Procedures

Cybersecurity policies serve as the foundational governance layer for managing organizational risk. As defined by industry standards, a policy document lists protected assets, outlines potential threats, and provides regulations to mitigate them. Effective policies must be written in parallel with execution procedures to ensure they are operationally sound. Mandatory components include the purpose, scope, roles, responsibilities, risk registers, and incident response plans. Beyond governance, these documents serve as operational references and awareness materials to reduce organizational exposure to social engineering. *(De Rosa, Gringoli & Bellicini, 2024)*



Figure 2.1 NIST vs ISO ([Raja Khan](#))

2.4 Cybersecurity Policy Frameworks (NIST and ISO/IEC 27001)

A security policy is a formal document that outlines the rules, expectations, and procedures for protecting an organization's assets. To evaluate the quality of a policy, two primary global standards are used:

- NIST Cybersecurity Framework (CSF):** The NIST CSF, published by the National Institute of Standards and Technology, provides a flexible and risk-based approach to managing cybersecurity. It is organized into five core functions that provide a high-level, strategic view of an organization's management of cybersecurity risk:
 - Identify:** Focuses on understanding the business context, the resources that support critical functions, and the related cybersecurity risks.
 - Protect:** Outlines appropriate safeguards to ensure the delivery of critical infrastructure services, such as access control and data security.
 - Detect:** Defines the activities to identify the occurrence of a cybersecurity event in a timely manner.
 - Respond:** Covers the actions taken once a cybersecurity incident is detected to contain its impact.
 - Recover:** Identifies appropriate activities to maintain plans for resilience and to restore any capabilities or services that were impaired due to a cybersecurity incident.
- ISO/IEC 27001:** ISO/IEC 27001 is an international standard that specifies the requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS). Unlike the NIST CSF which is a framework, ISO 27001 is a certifiable standard that focuses on:
 - Asset Management:** Ensuring that all information assets are identified and

appropriately protected.

Risk-Based Approach: Requiring organizations to perform a formal risk assessment and implement specific controls to mitigate those risks

Continuous Improvement: Following the Plan-Do-Check-Act (PDCA) cycle to ensure the security policy remains effective against evolving threats.

Compliance and Governance: Providing a structured methodology for organizations to manage sensitive information so that it remains secure, covering people, processes, and IT systems.

2.5 Analytic Hierarchy Process (AHP) in Risk Assessment

Analytic Hierarchy Process (AHP) is a structured technique for organizing and analyzing complex decisions, based on mathematics and psychology. In the context of cybersecurity, AHP is utilized to quantify subjective assessments of threats, vulnerabilities, and asset values into objective numerical data. This method is particularly effective for evaluating risk priorities when dealing with multifaceted threats like AI-driven phishing.

The AHP framework operates through three primary components in cybersecurity risk management:

- **Threat Assessment:** AHP allows security professionals to rank various phishing vectors (e.g., email-based, SMS/Smishing, or QR-code/Qishing) based on their probability of occurrence and potential impact. By using pairwise comparisons, the model determines which threat requires the most immediate defensive attention.
- **Vulnerability Analysis:** This component evaluates the weaknesses within an organization's infrastructure, such as lack of employee awareness, outdated email filters, or insufficient security policies. AHP helps in identifying which vulnerability poses the highest risk to the organization's integrity.
- **Asset Valuation:** Not all data carries the same weight. AHP is used to categorize and value assets, ranging from public information to highly sensitive intellectual property, ensuring that AI-generated policies prioritize the protection of the most critical "crown jewels" of the company.

By integrating AHP, the process of generating security policies becomes more data-driven. It ensures that the AI model does not just produce generic rules, but instead focuses on a mathematical hierarchy of risks that aligns with the organization's specific threat landscape and asset priority. (*jawhar et al.*)



Figure 2.2 MFA ([Xcitium](#))

2.6 Multi-Factor Authentication (MFA) in Cybersecurity

Multi-Factor Authentication (MFA) is a security mechanism that requires users to provide more than one form of verification to access a system. It combines multiple authentication factors, such as something the user knows (password), something the user has (OTP or token), and something the user has (biometric data).

In cybersecurity, MFA is essential for mitigating phishing attacks. Even if attackers successfully obtain user credentials, the additional verification layer prevents unauthorized access. This makes it significantly harder for attackers to exploit compromised accounts.

Therefore, MFA is widely adopted as a fundamental security control in modern systems and is recommended by international standards such as NIST and ISO/IEC 27001 to strengthen access protection and reduce cybersecurity risks.(National Institute of Standards and Technology) (NIST)



Figure 2.3 Email Security ([Fortinet](#))

2.7 Technical Controls and Email Security

Technical controls are security mechanisms designed to protect systems from cyber threats, including phishing attacks, by filtering and verifying incoming communications. In email security, these controls include filtering systems, spam detection tools, and authentication protocols such as DMARC, SPF, and DKIM, which ensure the legitimacy of email sources.

SPF (Sender Policy Framework): A DNS TXT record listing IP addresses and servers allowed to send emails on behalf of your domain. It prevents unauthorized parties from using your domain.

DKIM (DomainKeys Identified Mail): Adds a cryptographic signature (digital seal) to your emails. Receiving servers use this to confirm the email was not tampered with during transit.

DMARC (Domain-based Message Authentication, Reporting, and Conformance): Uses SPF and DKIM to determine if an email is authentic. It allows domain owners to instruct receiving mail servers on how to handle emails that fail authentication (e.g., placing them in spam or blocking them).

Additionally, technologies such as secure web gateways and URL or attachment scanning help detect and block malicious links and files before they reach users. By implementing these controls, organizations can significantly reduce the risk of phishing attacks and minimize exposure to malicious content. (P. Loshin, TechTarget, 2024.)

CHAPTER III

COMPARATIVE ANALYSIS AND DISCUSSION



Figure 3.1 NIST & ISO ([Veza](#) & [Security Compass](#))

3.1 AI-Based Cybersecurity Policies and Procedures

Artificial Intelligence (AI) plays a significant role in modern cybersecurity, especially in generating security policies and procedures. AI enables organizations to analyze multiple datasets such as infrastructure, risk profiles, and compliance standards simultaneously to produce effective and adaptive security policies.

The use of AI allows faster policy creation aligned with frameworks such as NIST and ISO, ensuring that organizations maintain compliance while adapting to evolving cyber threats. Additionally, AI can automate the enforcement of these policies through integration with systems such as firewalls, intrusion detection systems, and access control mechanisms.

Compared to traditional methods, AI-generated policies are more dynamic and capable of identifying vulnerabilities, improving incident response, and minimizing human error

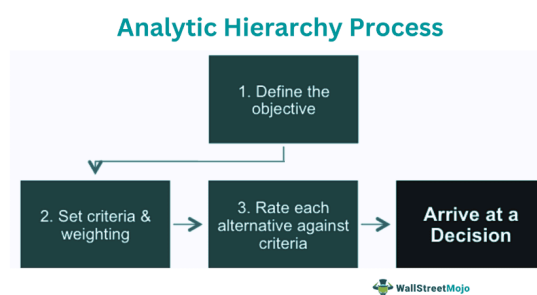


Figure 3.2 AHP ([Wallstreetmojo](#))

3.2 AI Techniques for Cyber Security Risk Detection

AI is widely used to assess and analyze cybersecurity risks, particularly in complex systems such as IoT and communication networks. One effective method is the use of the

Analytic Hierarchy Process (AHP) to evaluate risks based on three main factors: threats, vulnerabilities, and asset value.

This approach allows organizations to quantify risks and identify critical components within a network. By analyzing different layers such as perception, network, and application layers, AI helps in determining which parts of the system are most vulnerable to attacks.

Furthermore, AI-based risk analysis enables proactive cybersecurity strategies by predicting potential threats before they occur, allowing organizations to implement preventive measures rather than reactive solutions.

3.3 AI in Phishing Detection (Case Study: ChatGPT)

Phishing attacks are one of the most common cybersecurity threats, exploiting human behavior through social engineering techniques. AI models such as ChatGPT have shown promising results in detecting phishing emails by analyzing language patterns, urgency indicators, and suspicious content.

Unlike traditional rule-based systems, AI can adapt to new phishing patterns by understanding context and semantics, making it a powerful tool in email security systems.

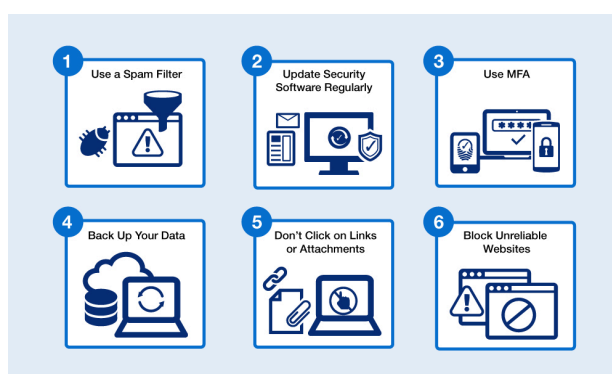


Figure 3.3. Phishing Attack Prevention ([Fortinet](#))

3.4 Mitigation Strategies for Phishing Attacks

Phishing attacks continue to evolve in complexity, especially with the integration of artificial intelligence by attackers. Therefore, effective mitigation strategies must combine technological solutions, human awareness, and organizational policies to reduce the risk of successful attacks.

A. AI-Based Phishing Detection Systems

Artificial Intelligence plays a crucial role in mitigating phishing by detecting suspicious patterns in emails and messages. AI systems analyze linguistic features, sender behavior, and contextual anomalies to identify potential phishing attempts.

Compared to traditional rule-based systems, AI-based detection is more adaptive and capable of recognizing new phishing techniques. These systems can be integrated into email filtering, web security gateways, and endpoint protection platforms to provide real-time threat detection.

B. Security Awareness and User Training

Security awareness is a critical component in mitigating phishing attacks, as these threats primarily exploit human behavior rather than system vulnerabilities. Organizations must implement continuous cybersecurity training programs to educate users on recognizing phishing indicators such as urgent language, suspicious links, and unexpected attachments. In addition, employees should be trained to verify sender identities before responding to sensitive requests and to follow secure communication practices. Simulated phishing campaigns can further enhance user preparedness by providing real-world scenarios that improve detection skills and response behavior over time. Through consistent training and awareness initiatives, organizations can significantly reduce the likelihood of successful phishing attempts.

C. Implementation of Multi-Factor Authentication (MFA)

Multi-Factor Authentication (MFA) serves as an essential security control for reducing the impact of phishing attacks. Even when attackers successfully obtain user credentials through phishing techniques, MFA introduces an additional verification layer that prevents unauthorized access. This typically includes one-time passwords (OTP), biometric verification, or authentication applications that require user interaction beyond standard login credentials. By implementing MFA, organizations can effectively limit the damage caused by compromised accounts and strengthen overall access control mechanisms, making it significantly more difficult for attackers to exploit stolen credentials.

D. AI-Generated and Adaptive Security Policies

Artificial Intelligence can be utilized to generate and continuously refine security policies in response to evolving phishing threats. These adaptive policies ensure that organizations remain aligned with current attack techniques and established security standards such as NIST and ISO. AI-generated policies can dynamically incorporate essential components such as incident response procedures, access control mechanisms, and secure communication guidelines. However, despite the efficiency of AI in policy generation, human validation remains necessary to ensure contextual accuracy and relevance. Without proper oversight, AI-generated policies may become overly generic or fail to address organization-specific risks effectively.

E. Technical Controls and Email Security Measures

Technical controls play a vital role in preventing phishing attacks before they reach end users. Organizations should implement robust email security mechanisms such as advanced filtering systems and spam detection tools to identify and block malicious communications. In addition, authentication protocols including Domain-based Message Authentication, Reporting, and Conformance (DMARC), Sender Policy Framework (SPF), and DomainKeys Identified Mail (DKIM) help verify the legitimacy of email sources. Complementary technologies such as secure web gateways and URL or attachment scanning further enhance protection by detecting malicious links and files. These combined measures significantly reduce the attack surface and prevent phishing attempts from progressing within the system.

F. Continuous Monitoring and Incident Response

Effective phishing mitigation requires continuous monitoring of system activities and the ability to respond rapidly to detected threats. Organizations should implement real-time monitoring tools to track suspicious behavior across networks and systems. In the event of a phishing incident, immediate response actions such as account isolation, credential resets, and threat analysis are essential to minimize potential damage. A well-defined incident response strategy ensures that organizations can quickly contain attacks, recover affected systems, and prevent similar incidents in the future. Continuous monitoring combined with efficient response mechanisms forms a critical defense layer in modern cybersecurity environments.

CHAPTER IV

CONCLUSION AND SUGGESTION

4.1 Conclusion

This study shows that phishing remains a major cybersecurity threat that continues to evolve, especially with the support of artificial intelligence. While AI provides significant advantages in generating security policies, analyzing risks, and detecting phishing attacks, it also introduces challenges such as lack of contextual understanding and the potential for creating an illusion of security.

The findings indicate that AI cannot fully replace human involvement, but instead should be used as a supporting tool to enhance decision-making and system protection. Effective phishing mitigation requires a multi-layered approach that combines AI technologies, user awareness, strong authentication mechanisms, technical controls, and continuous monitoring.

In conclusion, AI plays an important role in modern cybersecurity, but its effectiveness depends on proper implementation, continuous improvement, and integration with human expertise to ensure a more secure and reliable defense system

4.2 Suggestion

Based on the findings of this study, organizations are recommended to adopt a multi-layered cybersecurity approach that integrates AI detection systems, security policies, technical controls, and user awareness to effectively mitigate phishing risks. AI should be utilized as a decision-support tool rather than a full replacement for human expertise, ensuring better accuracy and contextual understanding. In addition, AI models must be continuously updated with relevant datasets to keep up with evolving phishing techniques. Strengthening user awareness through regular training and simulations is also essential, as phishing primarily targets human behavior. The implementation of strong authentication mechanisms, such as Multi-Factor Authentication (MFA), should be prioritized to reduce the impact of credential compromise. Furthermore, AI-generated policies must align with international standards such as NIST and ISO/IEC 27001 to maintain consistency and effectiveness. Finally, future research should focus on addressing AI limitations, including bias and over-classification, to improve the reliability of AI-driven cybersecurity systems.

BIBLIOGRAPHY

1. **Rosa, Sara De, Gringoli, F., & Bellicini, G.** (2024). *Hey ChatGPT, is this message phishing?*
[hey , chatgpt](#) [2024]
2. **Parandhaman, Vishnu P.** (2023). *Analysis Techniques Artificial intelligence for Detection of Cyber Security Risks in a Communication and Information Security*
[AI for Detection of Cyber Security](#) [2023]
3. **Jawhar, S., Miller, J., & Bitar, Z.** (2024). *AI-Based Cybersecurity Policies and Procedures.*
[AI Policed](#) [2024]
4. **National Institute of Standards and Technology (NIST 2024),**
[“Multi-Factor Authentication.”](#)
5. **P. Loshin,** “SPF, DKIM and DMARC: [What are they and how do they work together?](#)”
TechTarget, 2024.